

RDP — Remote Desktop Protocol

Servicio

RDP (Remote Desktop Protocol)

Puerto por defecto

3389/TCP (también UDP en implementaciones modernas)

Descripción

RDP es un protocolo propietario de Microsoft que proporciona una interfaz gráfica para conectarse a otro equipo a través de la red. Transmite la pantalla del servidor al cliente y envía los inputs del usuario (teclado, ratón) en sentido inverso. Es ampliamente utilizado para administración remota de servidores Windows y soporte técnico. Aunque incluye cifrado TLS, su exposición directa a Internet lo convierte en uno de los vectores de ataque más explotados globalmente.

Riesgos de seguridad

- **Fuerza bruta:** El puerto 3389 expuesto a Internet recibe millones de intentos de login automatizados diariamente.
- **Robo de credenciales / Credential stuffing:** Credenciales filtradas en otras brechas son probadas masivamente contra servicios RDP expuestos.
- **BlueKeep (CVE-2019-0708):** Vulnerabilidad crítica pre-autenticación en versiones antiguas de RDP que permite ejecución de código remoto sin credenciales (wormable).
- **DejaBlue (CVE-2019-1181/1182):** Vulnerabilidades similares a BlueKeep en versiones más recientes de Windows.
- **Pass-the-Hash / Pass-the-Ticket:** Hashes de credenciales capturados pueden usarse para autenticarse en RDP sin la contraseña.
- **Acceso remoto no autorizado:** Servidores RDP con credenciales débiles son vendidos en mercados oscuros (RDP shops) por tan solo \$3-\$10.
- **Ransomware deployment:** RDP es el vector de entrada número 1 para operadores de ransomware en entornos corporativos.

Escenarios de ataque

1. **Exposición directa a Internet + fuerza bruta:** Un servidor Windows con RDP en puerto 3389 accesible públicamente recibe ataques automatizados. Con contraseñas débiles o por defecto, el atacante obtiene acceso administrativo.
2. **BlueKeep exploit:** En sistemas Windows 7/Server 2008 sin parchear, el atacante envía paquetes RDP malformados y ejecuta código arbitrario sin credenciales, instalando ransomware o backdoors.

3. **RDP Man-in-the-Middle:** Sin Network Level Authentication (NLA), un atacante puede interceptar la sesión RDP antes de que se complete la autenticación.
4. **Compra de acceso RDP en dark web:** Actores de ransomware compran credenciales RDP previamente comprometidas en mercados como xDedic para acceder a redes corporativas.
5. **Lateral movement via RDP:** Tras comprometer un equipo, el atacante usa las credenciales obtenidas (Mimikatz) para moverse lateralmente a servidores críticos vía RDP.

Mitigaciones recomendadas

- **No exponer RDP directamente a Internet;** acceder solo a través de VPN.
- Habilitar **Network Level Authentication (NLA)** para requerir autenticación antes de establecer la sesión RDP.
- Implementar **autenticación multifactor (MFA)** para RDP.
- Cambiar el puerto por defecto (3389) a uno no estándar para reducir el ruido de escaneos automatizados.
- Implementar **Account Lockout Policy** para bloquear cuentas después de N intentos fallidos.
- Aplicar todos los parches de seguridad, especialmente MS19-0708 (BlueKeep) y sus variantes.
- Usar **Remote Desktop Gateway** para centralizar y controlar el acceso RDP.
- Restringir qué usuarios pueden iniciar sesión por RDP (Remote Desktop Users group).
- Monitorear logs de Windows Event ID 4625 (failed login) y 4624 (successful login) para detectar ataques.
- Implementar **Just-in-Time (JIT) access** con Azure AD o soluciones PAM para minimizar la ventana de exposición.

Nivel de exposición

Alto

Referencias

- Microsoft. *Remote Desktop Services Documentation*.
<https://learn.microsoft.com/en-us/windows-server/remote/remote-desktop-services/welcome-to-rds>
- CISA. *Security Guidance for Remote Access (RDP)*.
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a>
- Microsoft Security Advisory. *CVE-2019-0708 (BlueKeep)*.
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2019-0708>
- CISA. *Known Exploited Vulnerabilities Catalog*. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

